

Research proposal: Insider-related cyber security risk with Bayesian networks

Jan Ruijgrok
Open Universiteit Nederland

Abstract

Cyber security incidents are difficult to model statistically because breach and insider-threat data are scarce and rarely shared. Bayesian Networks (BNs) are nevertheless widely used in this domain because they combine expert knowledge with limited evidence and support inference under partial observability. Following a systematic review of standard BN models in cyber security (Chockalingam et al., 2017), this project develops a compact, causally motivated BN (8 nodes) for malicious insider-related security risk in an organizational IT environment. The central objective is to assess whether a manually designed BN yields both (i) plausible probabilistic inferences and (ii) competitive classification performance relative to learned structures and a naive Bayes baseline. Methodologically, the proposal follows the course assignment: (1) design and validation of an original BN in pyAgrum, (2) structure-learning experiments at $n = 100, 500$, and 1000 , and (3) classifier comparison using ROC/AUC.

1 Background

Standard (static) Bayesian Networks have become an established modelling technique in cyber and information security. Chockalingam et al. (2017) identified 17 standard BN models in the literature and analysed them along eight characteristics, including data sources for DAGs and CPTs, threat-actor type, application area, and validation approach. Their main findings are directly relevant to this project: historical incident data are limited and expert knowledge dominates CPT specification in most reviewed models; standard BNs focus disproportionately on malicious insiders while integrated insider-outsider models remain a gap; variables often span People-Process-Technology; and most models remain small (fewer than 40 nodes).

Representative insider-oriented work includes psychosocial and behavioural precursors and Bayesian models combining multiple insider indicators (Axelrad et al., 2013). This project does not replicate those large-scale models but abstracts their causal logic into a tractable 8-node network suitable for the assignment: explicit structure, interpretable CPTs, synthetic data for learning experiments, and classifier benchmarking.

What remains difficult in practice is to judge when a compact expert-built BN is “good enough” for analyst prioritisation under data scarcity. A flat classifier could rank cases but would not separate causal structure from parameters or support transparent what-if queries. Agent-based style evaluation is not applicable here; instead, pyAgrum provides a numerical laboratory for inference, structure recovery, and classification on synthetically generated cases drawn from the same ground-truth network (see Figure 1).

Within this setting the project compares expert-specified inference and scenario validation (Task 1) with structure-learning and classifier benchmarks (Task 2.2), plus a noisy-OR parameterisation of the incident node (RQ4). All learning data are synthetic; the work is a proof of concept, not operational SOC validation.

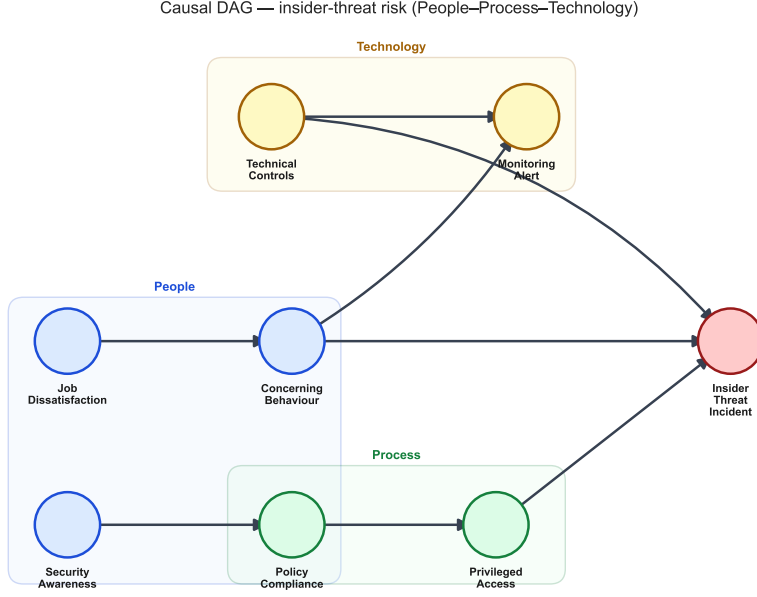


Figure 1: Proposed 8-node causal DAG for malicious insider-related cyber security risk (People–Process–Technology scope).

2 Research question

Working hypothesis: A domain-informed causal BN is an interpretable baseline for insider-related incident risk; structure learning adds structural recovery and predictive value mainly at larger sample sizes n .

We address the following research questions:

- **RQ1 (Model validity).** Does the manual BN yield plausible marginals, conditionals, and coherent effects for $P(\text{InsiderThreatIncident} = \text{yes} \mid \text{evidence})$?
- **RQ2 (Structure learning).** How well do search-and-score (hill climbing + BIC) and constraint-based (MIIC) methods recover the true structure at $n = 100, 500$, and 1000 ?
- **RQ3 (Classification).** How do ROC/AUC compare for the original BN, a learned BN, and naive Bayes on a held-out test set (train/test = 100/100)?
- **RQ4 (Noisy-OR).** Does noisy-OR parameterization of `InsiderThreatIncident` reduce CPT complexity while preserving plausible, monotonic risk accumulation vs. a full tabular CPT?

3 Research method

Problem and research questions

The study tests the hypothesis and **RQ1–RQ4** stated in Section 2: whether a compact expert BN supports plausible inference and whether standard learning procedures recover structure and predict incidents on synthetic data at small and moderate training sizes. The target quantity is $P(\text{InsiderThreatIncident} = \text{yes} \mid \text{evidence})$ with binary class variable **InsiderThreatIncident**. The design is an 8-node causal DAG integrating People, Process, and Technology factors (Chockalingam et al., 2017; Axelrad et al., 2013).

Research setup

- **Model world.** Eight discrete nodes: JobDissatisfaction, SecurityAwareness, PolicyCompliance, ConcerningBehaviour, PrivilegedAccess, TechnicalControls, MonitoringAlert, InsiderThreatIncident. Directed arcs follow the DAG in Figure 1.
- **Inference process.** Expert-specified CPTs in pyAgrum; optional noisy-OR on the incident node over activators ConcerningBehaviour=yes, PrivilegedAccess=excessive, TechnicalControls=weak.
- **What we vary.** (i) Training size for structure learning: $n \in \{100, 500, 1000\}$. (ii) Learning algorithm: hill climbing (search-and-score) vs. MIIC (constraint-based). (iii) Classifier type: original BN, learned BN, naive Bayes.
- **What we keep fixed.** Ground-truth DAG and expert CPTs for data generation; stratified train/test split 100/100 for classification; random seed protocol documented in the notebook.
- **Reference structure.** The hand-built DAG is the ground truth for structure-recovery metrics (skeleton/directed F_1 , Hamming distance, visual comparison).

Measurement and comparison

- **Task 1 outputs.** Marginals, conditional queries, scenario table (high/low/intermediate risk profiles), and sensitivity analysis on key CPT entries (e.g. noisy-OR leak).
- **Structure recovery.** Per- n metrics and side-by-side graphs vs. ground truth; stability over repeated resamples where reported.
- **Classification.** ROC curves and AUC for original, learned, and naive Bayes models; optional accuracy and confusion matrix.
- **Noisy-OR evaluation.** Parameter count, scenario rankings, and response curve vs. full tabular CPT on the incident node.
- **Link to RQ1–RQ4.** **RQ1:** scenario and sensitivity results. **RQ2:** structure-recovery tables and figures. **RQ3:** ROC/AUC comparison. **RQ4:** noisy-OR parsimony and monotonicity checks.

Execution

- Specify variables, arcs, and CPTs; implement the BN in pyAgrum (Task 1).
- Run inference, scenarios, and sensitivity analysis; export figures for the report.
- Generate synthetic databases from the ground-truth BN; run hill climbing and MIIC at $n = 100, 500, 1000$.
- Train and evaluate classifiers on stratified 100/100 splits; compute ROC/AUC and stability intervals.
- Document the full pipeline in a reproducible Jupyter notebook; write the short report.

Data analysis

Summarise inference scenarios and sensitivity findings against expert expectations (**RQ1**). Compare structure-recovery metrics across n and algorithms, emphasising skeleton vs. directed recovery (**RQ2**). Plot ROC curves and compare AUC intervals across classifiers (**RQ3**). Contrast noisy-OR and full CPT parameterisations on complexity and monotonic multi-cause risk (**RQ4**). Interpret all learning results as recoverability on synthetic data, not external validation on operational insider-incident records.

4 Risk analysis

Oversimplification of insider threat

The 8-node static model cannot represent full enterprise SOC complexity or insider–outsider collusion; scope must remain explicit. Mitigation: cite review gaps (Chockalingam et al., 2017); position the work as proof of concept, not operational deployment.

Subjective CPTs

Expert judgement dominates parameters; miscalibration could distort absolute risk levels. Mitigation: monotonicity checks, sensitivity analysis on key entries, and comparison with parameters learned on training data.

Small- n structure instability

Structure learning at $n = 100$ may yield spurious or reversed arcs; single runs can mislead. Mitigation: multiple random seeds; report stability intervals and visual diffs rather than one-off graphs.

Simulation circularity

Learning data are generated from the same BN used as ground truth, so metrics measure recoverability, not external validity. Mitigation: transparent generation protocol; interpret AUC as method comparison, not proof of SOC performance.

References

- [1] E. T. Axelrad, P. J. Sticha, O. Brdiczka, and J. Shen (2013). A Bayesian network model for predicting insider threats. In *IEEE Security and Privacy Workshops*, pp. 82–89.
- [2] S. Chockalingam, W. Pieters, A. Herdeiro Teixeira, and P. van Gelder (2017). Bayesian network models in cyber security: A systematic review. In *Proc. NordSec 2017* (LNCS 10674, pp. 105–122). Springer. https://doi.org/10.1007/978-3-319-70290-2_7